

ข้อตกลงการประมวลผลข้อมูลส่วนบุคคล (Data Processing Agreement - DPA)

ข้อตกลงการประมวลผลข้อมูลส่วนบุคคล (DPA) ฉบับนี้ ถือเป็นส่วนหนึ่งของเงื่อนไขการให้บริการ (Terms of Service) โดยมีผลผูกพันระหว่าง [ชื่อนิติบุคคลผู้ให้บริการ JorPorHub] ซึ่งต่อไปในข้อตกลงนี้จะเรียกว่า "ผู้ประมวลผลข้อมูลส่วนบุคคล" (Data Processor) และ นิติบุคคลหรือองค์กรที่ท่านเป็นตัวแทนในการสมัครใช้งาน ซึ่งต่อไปในข้อตกลงนี้จะเรียกว่า "ผู้ควบคุมข้อมูลส่วนบุคคล" (Data Controller) ท่านที่ท่านกดยอมรับเงื่อนไขการให้บริการและสร้างบัญชีผู้ใช้งานสำเร็จ

ทั้งสองฝ่ายมีความประสงค์จะกำหนดหน้าที่และความรับผิดชอบเกี่ยวกับการประมวลผลข้อมูลส่วนบุคคล ให้เป็นไปตามพระราชบัญญัติคุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 (PDPA) และกฎหมายลำดับรองที่เกี่ยวข้อง จึงตกลงกันดังนี้

ข้อ 1. คำนิยาม

"กฎหมายคุ้มครองข้อมูล" หมายถึง พระราชบัญญัติคุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 และกฎหมาย ประกาศ ระเบียบลำดับรองที่เกี่ยวข้อง รวมถึงที่จะมีการแก้ไขเพิ่มเติม

"ข้อมูลส่วนบุคคล" "ข้อมูลส่วนบุคคลอ่อนไหว" "ผู้ควบคุมข้อมูลส่วนบุคคล" "ผู้ประมวลผลข้อมูลส่วนบุคคล"

"เจ้าของข้อมูลส่วนบุคคล" ให้มีความหมายตามที่กำหนดไว้ในกฎหมายคุ้มครองข้อมูล

"บริการ" หมายถึง แพลตฟอร์ม JorPorHub ซึ่งเป็นระบบซอฟต์แวร์ให้บริการบริหารจัดการงานความปลอดภัย อาชีวอนามัย และสภาพแวดล้อมในการทำงาน

"เหตุการณ์ละเมิดข้อมูลส่วนบุคคล" หมายถึง เหตุการณ์ที่ทำให้เกิดการเข้าถึง เปิดเผย ทำลาย แก้ไข หรือสูญหาย ของข้อมูลส่วนบุคคลโดยไม่ได้รับอนุญาตหรือโดยไม่ชอบด้วยกฎหมาย

"ผู้ประมวลผลช่วง" (Sub-processor) หมายถึง ผู้ให้บริการภายนอกที่ผู้ประมวลผลข้อมูลว่าจ้างให้ประมวลผลข้อมูลส่วนบุคคลบางส่วนแทน เช่น ผู้ให้บริการโครงสร้างพื้นฐานคลาวด์

ข้อ 2. บทบาทของคู่สัญญา

2.1 ผู้ควบคุมข้อมูลตกลงและรับรองว่าตนเป็นผู้ควบคุมข้อมูลส่วนบุคคลของพนักงาน ลูกจ้าง ผู้รับเหมา และบุคคลอื่นที่เกี่ยวข้องซึ่งถูกบันทึกในระบบ และเป็นผู้รับผิดชอบแต่เพียงผู้เดียวในการกำหนดฐานทางกฎหมาย ขอความยินยอม (หากจำเป็น) และแจ้งประกาศความเป็นส่วนตัวแก่เจ้าของข้อมูลตามที่กฎหมายกำหนด

2.2 ผู้ประมวลผลข้อมูลตกลงประมวลผลข้อมูลส่วนบุคคลเฉพาะตามคำสั่งที่บันทึกไว้เป็นลายลักษณ์อักษรของผู้ควบคุมข้อมูล (รวมถึงที่ระบุในภาคผนวก ก. แนบท้ายข้อตกลงนี้) และจะไม่ประมวลผลข้อมูลเพื่อวัตถุประสงค์อื่นใดนอกเหนือจากที่ตกลงกันไว้ เว้นแต่กฎหมายกำหนดให้ต้องกระทำเช่นนั้น

ข้อ 3. หน้าที่ของผู้ประมวลผลข้อมูลส่วนบุคคล

ตามมาตรา 40 แห่งพระราชบัญญัติคุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 ผู้ประมวลผลข้อมูลตกลงปฏิบัติหน้าที่ดังต่อไปนี้:

(ก) ประมวลผลข้อมูลส่วนบุคคลเฉพาะตามคำสั่งของผู้ควบคุมข้อมูลเท่านั้น เว้นแต่คำสั่งนั้นขัดต่อกฎหมาย

(ข) จัดให้มีมาตรการรักษาความมั่นคงปลอดภัยที่เหมาะสมตามที่ระบุในภาคผนวก ข. และทบทวนมาตรการดังกล่าวตามความจำเป็น

(ค) แจ้งให้ผู้ควบคุมข้อมูลทราบกรณีมีเหตุการณ์ละเมิดข้อมูลส่วนบุคคลที่เกิดขึ้น โดยไม่ชักช้าและภายในระยะเวลาไม่เกิน 24 ชั่วโมงนับแต่ทราบเหตุ เพื่อให้ผู้ควบคุมข้อมูลสามารถแจ้งสำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล (สคส.) ได้ภายใน 72 ชั่วโมงตามที่มาตรา 37 (4) กำหนด

- (ง) จัดทำและเก็บรักษาบันทึกการประมวลผลข้อมูลส่วนบุคคล (Record of Processing) ในส่วนที่เกี่ยวข้องกับบริการ
- (จ) ให้ความช่วยเหลือผู้ควบคุมข้อมูลตามสมควรในการตอบสนองคำขอใช้สิทธิของเจ้าของข้อมูล (สิทธิเข้าถึง แก้ไข ลบ ถัดถ้าน โอนย้าย ระบุการใช้ และถอนความยินยอม)
- (ฉ) ไม่เปิดเผยหรือโอนข้อมูลส่วนบุคคลให้บุคคลภายนอก เว้นแต่เป็นการใช้ผู้ประมวลผลช่วงที่ได้รับการยินยอมล่วงหน้าตามข้อ 5 หรือตามที่กฎหมายกำหนด
- (ช) ลบ ทำลาย หรือส่งคืนข้อมูลส่วนบุคคลทั้งหมดแก่ผู้ควบคุมข้อมูลเมื่อสิ้นสุดสัญญาหรือตามคำขอ ตามที่กำหนดในข้อ 8
- (ซ) ยินยอมให้ผู้ควบคุมข้อมูลหรือผู้ตรวจสอบที่ได้รับมอบหมายเข้าตรวจสอบการปฏิบัติตามข้อตกลงนี้ได้ตามสมควร ตามที่กำหนดในข้อ 9
- (ณ) ควบคุมดูแลให้พนักงาน ผู้บริหาร และบุคคลที่เกี่ยวข้องของผู้ประมวลผลข้อมูลที่มีสิทธิเข้าถึงข้อมูลส่วนบุคคล ต้องรักษาความลับของข้อมูลนั้น (Confidentiality Undertaking)

ข้อ 4. หน้าที่ของผู้ควบคุมข้อมูลส่วนบุคคล

- 4.1 รับรองว่าคำสั่งประมวลผลข้อมูลที่ให้แก่ผู้ประมวลผลข้อมูลชอบด้วยกฎหมายคุ้มครองข้อมูล
- 4.2 รับผิดชอบในการแจ้งประกาศความเป็นส่วนตัว (Privacy Notice) และขอความยินยอมจากเจ้าของข้อมูล (พนักงาน/ลูกจ้าง) ตามฐานทางกฎหมายที่เหมาะสม
- 4.3 แจ้งผู้ประมวลผลข้อมูลทันทีหากมีการเปลี่ยนแปลงคำสั่งประมวลผล หรือได้รับคำขอใช้สิทธิจากเจ้าของข้อมูลที่ต้องอาศัยความช่วยเหลือจากผู้ประมวลผลข้อมูล
- 4.4 รับผิดชอบความถูกต้องของข้อมูลที่นำเข้าสู่ระบบ

ข้อ 5. ผู้ประมวลผลช่วง (Sub-processors)

- 5.1 ผู้ควบคุมข้อมูลให้ความยินยอมทั่วไป (general authorisation) แก่ผู้ประมวลผลข้อมูลในการว่าจ้างผู้ประมวลผลช่วงตามรายชื่อที่ระบุในภาคผนวก ก. แนบท้ายข้อตกลงนี้ เพื่อการให้บริการโครงสร้างพื้นฐาน (เช่น ฐานข้อมูล พื้นที่จัดเก็บไฟล์ และการโฮสต์เว็บแอปพลิเคชัน)
- 5.2 ผู้ประมวลผลข้อมูลจะแจ้งให้ผู้ควบคุมข้อมูลทราบล่วงหน้าไม่น้อยกว่า [30] วัน ผ่านทางอีเมลของผู้ดูแลระบบ (Admin) หรือ ประกาศบนหน้าแพลตฟอร์ม หากมีการเพิ่มหรือเปลี่ยนแปลงผู้ประมวลผลช่วง เพื่อให้ผู้ควบคุมข้อมูลมีโอกาสคัดค้านได้ตามสมควร
- 5.3 ผู้ประมวลผลข้อมูลต้องกำหนดให้ผู้ประมวลผลช่วงมีหน้าที่ด้านการคุ้มครองข้อมูลไม่ต่ำกว่าที่กำหนดไว้ในข้อตกลงนี้ และผู้ประมวลผลข้อมูลยังคงต้องรับผิดชอบต่อการกระทำของผู้ประมวลผลช่วงเสมือนเป็นการกระทำของตนเอง

ข้อ 6. การโอนข้อมูลไปต่างประเทศ

- 6.1 ผู้ควบคุมข้อมูลรับทราบว่าข้อมูลส่วนบุคคลอาจถูกจัดเก็บหรือประมวลผลบนเซิร์ฟเวอร์ที่ตั้งอยู่นอกราชอาณาจักรไทย (รายละเอียดที่ตั้งเซิร์ฟเวอร์ระบุในภาคผนวก ค.)
- 6.2 กรณีมีการโอนข้อมูลไปยังต่างประเทศ ผู้ประมวลผลข้อมูลจะดำเนินการให้มั่นใจว่าประเทศปลายทางมีมาตรฐานการคุ้มครองข้อมูลส่วนบุคคลที่เพียงพอตามประกาศของคณะกรรมการคุ้มครองข้อมูลส่วนบุคคล หรือจัดให้มีมาตรการคุ้มครองที่เหมาะสมอื่นตามมาตรา 28 และ 29 แห่งกฎหมายคุ้มครองข้อมูล เช่น การทำข้อสัญญามาตรฐาน (Standard Contractual Clauses) กับผู้ให้บริการปลายทาง

ข้อ 7. เหตุการณ์ละเมิดข้อมูลส่วนบุคคล (Data Breach)

- 7.1 เมื่อผู้ประมวลผลข้อมูลทราบหรือมีเหตุอันควรสงสัยว่าเกิดเหตุการณ์ละเมิดข้อมูลส่วนบุคคล จะแจ้งผู้ควบคุมข้อมูลเป็นลายลักษณ์อักษรโดยไม่ชักช้า ภายในระยะเวลาไม่เกิน [24] ชั่วโมง
- 7.2 การแจ้งดังกล่าวต้องระบุอย่างน้อย: ลักษณะของเหตุการณ์ละเมิด ประเภทและจำนวนข้อมูล/เจ้าของข้อมูลที่ได้

รับผลกระทบ ผลกระทบที่อาจเกิดขึ้น และมาตรการที่ได้ดำเนินการหรือจะดำเนินการเพื่อแก้ไข/บรรเทาผลกระทบ

7.3 ผู้ประมวลผลข้อมูลจะให้ความร่วมมือและข้อมูลที่จำเป็นแก่ผู้ควบคุมข้อมูลอย่างเต็มที่ เพื่อให้ผู้ควบคุมข้อมูลสามารถปฏิบัติตามหน้าที่แจ้งเหตุต่อสำนักงานคณะกรรมการคุ้มครองข้อมูลส่วนบุคคลภายใน 72 ชั่วโมงตาม มาตรา 37 (4) และแจ้งเจ้าของข้อมูลตามที่กฎหมายกำหนด

ข้อ 8. การเก็บรักษา การลบ และการส่งคืนข้อมูล

8.1 ผู้ประมวลผลข้อมูลจะเก็บรักษาข้อมูลส่วนบุคคลเท่าที่จำเป็นตามระยะเวลาที่ผู้ควบคุมข้อมูลใช้บริการ และตามที่กฎหมายกำหนด (เช่น เอกสารที่ต้องยื่นต่อหน่วยงานราชการ)

8.2 เมื่อสัญญาการใช้บริการสิ้นสุดลงไม่ว่าด้วยเหตุใด ผู้ประมวลผลข้อมูลจะ (ก) ส่งคืนข้อมูลส่วนบุคคลทั้งหมดในรูปแบบที่ใช้งานได้ (เช่น ไฟล์ Excel/PDF) แก่ผู้ควบคุมข้อมูลภายใน [30] วัน และ (ข) ลบหรือทำลายข้อมูลส่วนบุคคลทั้งหมดที่เหลืออยู่ในระบบและสำเนาสำรอง (backup) ภายใน [90] วันถัดจากนั้น เว้นแต่กฎหมายกำหนดให้ต้องเก็บรักษาไว้

ข้อ 9. สิทธิในการตรวจสอบ (Audit)

ผู้ควบคุมข้อมูลมีสิทธิขอตรวจสอบมาตรการรักษาความปลอดภัยและการปฏิบัติตามข้อตกลงนี้ของผู้ประมวลผลข้อมูล โดยแจ้งล่วงหน้าเป็นลายลักษณ์อักษรไม่น้อยกว่า [15] วันทำการ และไม่เกิน [1] ครั้งต่อปี เว้นแต่มีเหตุการละเมิดข้อมูลเกิดขึ้น ทั้งนี้ ผู้ประมวลผลข้อมูลอาจเลือกให้ข้อมูล/รายงานผลการตรวจสอบที่ได้รับจากหน่วยงานภายนอก (เช่น ผลการประเมินความปลอดภัยของผู้ให้บริการคลาวด์) แทนการตรวจสอบโดยตรงได้ตามความเหมาะสม

ข้อ 10. ความรับผิดชอบ

คู่สัญญาแต่ละฝ่ายจะรับผิดชอบต่อความเสียหายที่เกิดขึ้นจากการฝ่าฝืนหน้าที่ของตนตามข้อตกลงนี้และตามกฎหมายคุ้มครองข้อมูล ทั้งนี้ ขอบเขตและเพดานความรับผิดชอบให้เป็นไปตามที่ตกลงกันไว้ในเงื่อนไขการให้บริการ (Terms of Service) หรือสัญญาให้บริการหลักระหว่างคู่สัญญา

ข้อ 11. การรักษาความลับ

คู่สัญญาแต่ละฝ่ายตกลงเก็บรักษาข้อมูลของอีกฝ่ายที่ได้รับทราบจากการปฏิบัติตามข้อตกลงนี้ไว้เป็นความลับ และจะไม่เปิดเผยต่อบุคคลภายนอก เว้นแต่ได้รับความยินยอมเป็นลายลักษณ์อักษร หรือตามที่กฎหมายกำหนด

ข้อ 12. ระยะเวลาและการสิ้นสุด

ข้อตกลงนี้มีผลบังคับใช้ตลอดระยะเวลาที่ผู้ควบคุมข้อมูลใช้บริการตามเงื่อนไขการให้บริการ และจะสิ้นสุดโดยอัตโนมัติเมื่อการให้บริการสิ้นสุดลง เว้นแต่หน้าที่บางประการ (เช่น การรักษาความลับ การลบ/ส่งคืนข้อมูล) จะยังคงมีผลผูกพันต่อไปตามระยะเวลาที่กำหนดไว้ในข้อตกลงนี้

ข้อ 13. กฎหมายที่ใช้บังคับ

ข้อตกลงนี้อยู่ภายใต้บังคับและตีความตามกฎหมายไทย และให้ศาลไทยเป็นผู้มีเขตอำนาจในการพิจารณาข้อพิพาทที่เกิดขึ้น

ภาคผนวก ก. รายละเอียดการประมวลผลข้อมูลส่วนบุคคล

หัวข้อ	รายละเอียด
วัตถุประสงค์การประมวลผล	บันทึกและติดตามอุบัติเหตุ/เหตุการณ์ไม่ปลอดภัย, ตรวจสอบความปลอดภัยและอุปกรณ์, บริหารจัดการ PPE, บริหารหลักสูตรฝึกอบรมด้านความปลอดภัย, จัดทำรายงานยื่นหน่วยงานราชการ (เช่น กท.16, สปร.5)
ประเภทข้อมูลส่วนบุคคล	ชื่อ-นามสกุล, ตำแหน่ง, แผนก, ข้อมูลติดต่อ, ประวัติการฝึกอบรม, ภาพถ่ายประกอบเหตุการณ์/การตรวจสอบ
ข้อมูลอ่อนไหว	ข้อมูลสุขภาพที่เกี่ยวข้องกับการบาดเจ็บจากการทำงาน (ลักษณะการบาดเจ็บ, ส่วนของร่างกายที่ได้รับผลกระทบ)
หมวดหมู่เจ้าของข้อมูล	พนักงาน, ลูกจ้าง, ผู้รับเหมา และบุคคลอื่นที่ปฏิบัติงานในสถานประกอบการของผู้ควบคุมข้อมูล
ระยะเวลาการประมวลผล	ตลอดระยะเวลาที่ใช้บริการ และตามที่กำหนดในข้อ 8 ของข้อตกลงนี้

ภาคผนวก ข. มาตรการรักษาความมั่นคงปลอดภัย (Technical and Organisational Measures)

- การควบคุมสิทธิ์การเข้าถึงข้อมูลแบบแบ่งตามองค์กร (Row-Level Security) เพื่อป้องกันการเข้าถึงข้อมูลข้ามองค์กร
- การเข้ารหัสข้อมูลระหว่างส่ง (HTTPS/TLS) และข้อมูลขณะพัก (encryption at rest)
- การกำหนดสิทธิ์การเข้าถึงตามบทบาทหน้าที่ (Role-Based Access Control)
- การจับเก็บบันทึกการเข้าถึงและการเปลี่ยนแปลงข้อมูล (Audit log) ที่สำคัญ
- นโยบายรักษาความลับสำหรับพนักงาน/ผู้ดูแลระบบที่เข้าถึงข้อมูลส่วนบุคคล
- แผนรับมือและแจ้งเหตุการละเมิดข้อมูลส่วนบุคคล
- การสำรองข้อมูล (backup) และแผนกู้คืนระบบ

ภาคผนวก ค. รายชื่อผู้ประมวลผลช่วง (Sub-processors)

ผู้ให้บริการ	บริการที่ให้	ที่ตั้งเซิร์ฟเวอร์/ประเทศ
Supabase	ฐานข้อมูล, พื้นที่จัดเก็บไฟล์ (Storage), ระบบยืนยันตัวตน (Auth)	[ระบุมิติภาคเซิร์ฟเวอร์ที่เลือกใช้ เช่น Singapore]
Vercel	โฮสต์เว็บแอปพลิเคชัน (Frontend Hosting)	[ระบุมิติภาค/ประเทศ]

หมายเหตุ: รายชื่อนี้ต้องปรับปรุงให้ตรงกับผู้ให้บริการจริงที่ใช้งาน และแจ้งผู้ควบคุมข้อมูลทุกครั้งที่มีการเปลี่ยนแปลงตามข้อ 5.2